

DEVIN TAKE-HOME · COGNITION

# Autonomous Dependency Security

Turning never-ending CVE toil into a hands-free remediation loop - with Devin doing the work.

Presented by **Deon Menezes** · live on a fork of Apache Superset

# Dependency security is endless toil for engineering teams

- ◆ Scanners file a steady **drip of CVE issues** - every week, forever
- ◆ Each one is the same grind: **triage** → **bump** → **fix conflicts** → **test** → **PR** → **merge**
- ◆ Low-value, high-interrupt work that pulls **senior engineers off the roadmap**
- ◆ Skip it and **security debt and audit risk compound**

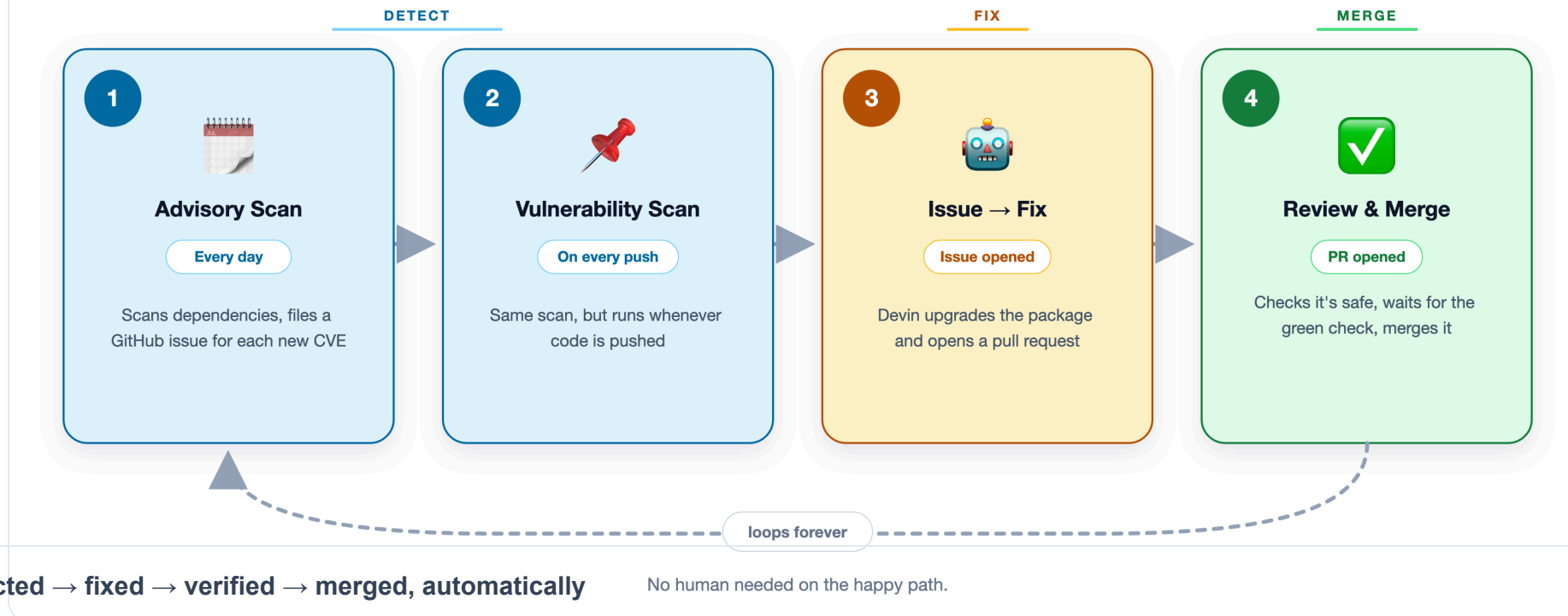
Important, tedious, and never actually done - the perfect job to automate.

## THE IDEA

# An event-driven loop where Devin does the fixing

### The 4 Devin Automations

A CVE is found, fixed, and merged - automatically.



# The loop in action

- ◆ A scan files a **devin-remediate** issue for each new CVE
- ◆ Devin opens a scoped PR - “**security: upgrade X → Y**”, “**Closes #N**”
- ◆ The engine posts the **deps-verify** check; branch protection requires it
- ◆ Devin auto-reviews scope + green check, then **squash-merges** and the issue closes
- ◆ A live **control room** shows every run, PR link, and ACU spent

**One CVE issue in → one merged, verified pull request out.  
No human on the happy path.**

## HOW · KEY DECISIONS IN THE CODE

- ◆ **Group by package** - one PR per package, not one per CVE
- ◆ **Guardrails**: no published fix, or a **major-version bump** → held for a human
- ◆ **The engine is the CI** - posts a first-class **deps-verify** status (private fork, Actions off)
- ◆ **Dry-run, a run ledger, and a report** so a lead can see it working

## Every path - including the guardrails

**Green = automated · amber = decision · red = human hand-off**

# Dependabot flags it. Devin closes it.

- ◆ A bot bumps the pin, then leaves a **red PR for a human**
- ◆ The real cost is the fix with consequences: **API changes, lockfile regen, dependency conflicts, broken tests**
- ◆ Devin does the **coding work a script can't**, then writes a PR a reviewer trusts
- ◆ So route it: cheap tools clear trivial bumps, **Devin takes the long tail** that lands on an engineer's desk

The bump is the easy 20%. Devin does the 80% that reaches a human today.

# Live on a real repository

**15 / 17**

CVEs remediated and merged - hands-free

**2 held**

correctly: flask (major migration) & paramiko (no fix)

**0**

un-verified merges - every PR gated by deps-verify

**4**

Devin automations, chained into one closed loop



# How this scales past the demo

- ◆ Make the gate **semantic** - run the real test suite, not just pin integrity
- ◆ **Multi-repo, multi-ecosystem** - npm, cargo, go.mod via per-ecosystem parsers
- ◆ Notify **Slack / PagerDuty**; severity-aware **SLAs** for critical CVEs
- ◆ **Per-team policy**: auto-merge patches, review minors, escalate majors
- ◆ One source of truth - **Postgres + a metrics backend** as volume grows

THANK YOU

# Dependency security, on autopilot

Detect → fix → verify → merge. Humans only  
on the exceptions.

**Deon Menezes** · built with Devin